LADEKLAR

RECHTLICHE MUSTER

# Technische und organisatorische Maßnahmen (TOM) nach Art. 32 DSGVO

Hinweis – Muster, keine Rechtsberatung.

# Technische und organisatorische Maßnahmen (TOM) nach Art. 32 DSGVO

> **Hinweis – Muster, keine Rechtsberatung.** Dieses Dokument ist ein Mustertext für LADEKLAR. Es ersetzt keine Rechtsberatung und ist vor Verwendung anwaltlich prüfen zu lassen. Platzhalter in [eckigen Klammern] ausfüllen. Mit „Prüfhinweis“ gekennzeichnete Anmerkungen sind vor Verwendung zu entfernen. Die TOM müssen der tatsächlichen Umsetzung entsprechen; jede Angabe ist vor Veröffentlichung technisch zu bestätigen. Recherchestand: 16.10.2026.

Anlage 2 zum Auftragsverarbeitungsvertrag von [Firma] [Rechtsform] („Anbieter“)

Stand: [Datum] · Version [1.0] · verantwortlich für die Pflege: [Name, Funktion]

## 1. Grundlagen

(1) Die Maßnahmen berücksichtigen den Stand der Technik, die Implementierungskosten, Art, Umfang, Umstände und Zwecke der Verarbeitung sowie die Risiken für die Rechte und Freiheiten der betroffenen Personen (Art. 32 Abs. 1 DSGVO). Besonderes Gewicht haben die Vertraulichkeit von Beschäftigtendaten, die Integrität von Abliefernachweisen und die Verfügbarkeit während laufender Touren.

(2) Systemüberblick: Server in Node.js 22 ohne Web-Framework, Datenbank SQLite (`node:sqlite`), Live-Aktualisierung per Server-Sent Events, Web-Push mit VAPID, Web-App und installierbare PWA, optional Store-App (Capacitor). Betrieb ausschließlich in einem Rechenzentrum in Deutschland.

(3) Die Spalte „Status“ ist vor Veröffentlichung auszufüllen: **U** = umgesetzt, **G** = geplant bis [Datum]. Zeilen, die die Software selbst betreffen, sind mit dem Code-Stand vom 17.10.2026 abgeglichen und bereits ausgefüllt (U = im Code vorhanden, G = im Code nicht vorhanden). Zeilen mit [U/G] betreffen Betrieb und Organisation und sind vom Anbieter auszufüllen.

## 2. Vertraulichkeit (Art. 32 Abs. 1 lit. b DSGVO)

### 2.1 Zutrittskontrolle

| Maßnahme | Status |
|---|---|
| Betrieb ausschließlich in einem Rechenzentrum von [Hosting-Anbieter] in [Ort], Deutschland, zertifiziert nach ISO/IEC 27001 | [U/G] |
| Physische Sicherheit durch das Rechenzentrum: Zutritt nur für berechtigte Personen, Videoüberwachung, Einbruchmeldeanlage, Protokollierung, Brandschutz (Nachweis durch Zertifikat des Rechenzentrums) | [U/G] |
| Keine eigenen Server- oder Datenträgerstandorte des Anbieters; Arbeitsplätze ohne lokale Kopien von Kundendaten | [U/G] |

## 2.2 Zugangskontrolle (Systeme)

| Maßnahme | Status |
|---|---|
| Transportverschlüsselung aller Verbindungen mit TLS 1.2 oder höher durch den vorgeschalteten Webserver; unverschlüsselte Verbindungen werden umgeleitet | [U/G] |
| HSTS-Header ( `max-age=31536000; includeSubDomains` ), sobald die Plattform mit einer `https://` -Adresse ( `BASE_URL` ) betrieben wird | U |
| Passwörter von Admins, Disponenten und Lizenzgeber werden mit scrypt und individuellem Salt (16 Byte) gehasht (Parameter N = 16384, r = 8, p = 1); Klartext-Passwörter werden nicht gespeichert; Mindestlänge 10 Zeichen | U |
| Fahrer-PINs (sechsstellig) werden ebenfalls mit scrypt und Salt gehasht; wegen der geringen Länge der PIN ist die Login-Sperre zwingender Bestandteil | U |
| Login-Sperre mit Steigerung je Zugang: nach 5 Fehlversuchen 15 Minuten, nach 10 eine Stunde, nach 15 und nach jeweils 5 weiteren 24 Stunden; erst eine erfolgreiche Anmeldung oder ein neuer PIN bzw. ein neues Passwort setzt den Zähler zurück; bei der ersten 24-Stunden-Sperre erhalten Admins und Disponenten des Kunden eine Mitteilung; gilt für Passwort, PIN und falsche Codes der Zwei-Faktor-Anmeldung | U |
| Anfragebegrenzung je IP-Adresse: höchstens 20 Anmeldeversuche je Minute (Büro, Fahrer und Einladungslink zusammen) und höchstens 60 Abrufe von Einladungsdaten je Minute; jeder Fehlversuch steht mit Zeitpunkt und IP-Adresse im Audit-Log | U |
| Bei unbekannter E-Mail-Adresse, Handynummer, unbekanntem Firmencode oder ungültigem Einladungslink prüft der Server trotzdem einen Hash, damit die Antwortzeit nicht verrät, ob es den Zugang gibt | U |
| Hinter einem Reverse Proxy ermittelt der Server die Adresse des Geräts aus `X-Forwarded-For` , gezählt von rechts ( `TRUST_PROXY=1` , `TRUST_PROXY_HOPS` = Anzahl vertrauenswürdiger Proxys); vom Gerät selbst gesendete Einträge zählen nicht | U |
| Sitzungs-Tokens mit 256 Bit Zufall; in der Datenbank nur als Hash (SHA-256) gespeichert, zusammen mit Erstellungszeit, Ablaufzeit und Browser-Kennung (User-Agent, höchstens 160 Zeichen) | U |
| Sitzungs-Cookie `lk_sid` mit den Attributen `HttpOnly` und `SameSite=Lax` , `Secure` beim Betrieb über HTTPS; Laufzeit 90 Tage für Fahrer und 14 Tage für Büro-Zugänge und Lizenzgeber, jeweils ab der letzten Nutzung | U |
| Ende von Sitzungen: Abmelden beendet die Sitzung des Geräts. Eine Passwortänderung beendet alle anderen Sitzungen des Nutzers und alle seine Push-Abonnements; die App richtet Push auf dem aktuellen Gerät danach ohne Nachfrage neu ein. Neuer PIN bzw. neues Passwort durch Admin oder Lizenzgeber, Sperren und Löschen eines Zugangs, Löschen des Mandanten und das Zurücksetzen des Lizenzgeber-Passworts auf dem Server beenden sofort alle Sitzungen, Push-Abonnements und Live-Verbindungen der betroffenen Nutzer | U |
| Startpasswort (bei neuen Büro-Zugängen ohne selbst gesetztes Passwort, nach einem Passwort-Reset durch den Admin und nach einem Reset des Admins durch den Lizenzgeber): Bis zur Vergabe eines eigenen Passworts lehnt der Server alle Aktionen außer Passwortänderung, Profil und Mitteilungen ab; auch Dateien (außer Logo und App-Symbol), Live-Verbindung, Push-Anmeldung, Uploads und Exporte sind gesperrt | U |
| Einladungslinks für Fahrer ( `/i/<Token>` ): zufälliges Token mit 144 Bit, einmal verwendbar, 14 Tage gültig, zusätzlich mit PIN; die Anmeldung löscht das Token; ein neuer PIN erzeugt ein neues Token; für gesperrte und gelöschte Fahrer und gekündigte Mandanten ungültig | U |
| API-Schlüssel (Premium): in der Datenbank nur als Hash (SHA-256) gespeichert; der Schlüssel wird nur einmal bei der Erzeugung angezeigt, danach nur die letzten 4 Zeichen; durch Neuerzeugung widerrufbar (der alte Schlüssel wird ungültig) und abschaltbar; gilt nur bei aktiver Lizenz bzw. in der Testphase; höchstens 600 Anfragen je Minute und Mandant | U |
| Server-Administration nur über SSH mit Schlüssel, ohne Passwort-Anmeldung; Zugang für [Anzahl] namentlich benannte Personen; Protokollierung | [U/G] |

| Maßnahme | Status |
|---|---|
| Zwei-Faktor-Anmeldung (TOTP nach RFC 6238: 6 Stellen, 30 Sekunden, ±1 Zeitschritt; jeder Code nur einmal gültig) als Option für Lizenzgeber, Admins und Disponenten; ein falscher Code zählt als Fehlversuch; Ausschalten nur mit dem Passwort; die Lizenzgeber-Konsole zeigt einen Warnhinweis, solange sie aus ist | U |
| Wiederherstellung bei verlorenem Handy: Ein neues Passwort durch den Admin (für Disponenten) bzw. durch den Lizenzgeber (für den Admin) schaltet die Zwei-Faktor-Anmeldung aus; für den Lizenzgeber selbst nur auf dem Server mit `node server/index.js reset-platform-password` | U |
| Zwei-Faktor-Anmeldung als Pflicht für einen Mandanten oder die Lizenzgeber-Konsole; geheimer Schlüssel der Zwei-Faktor-Anmeldung verschlüsselt speichern (derzeit unverschlüsselt in der Datenbank) | G |
| Zwei-Faktor-Authentifizierung für die Konten beim Hosting-Anbieter | [U/G] |

## 2.3 Zugriffskontrolle (Daten)

| Maßnahme | Status |
|---|---|
| Rollenmodell (Lizenzgeber, Admin, Disponent, Fahrer) mit festgelegten Rechten; Fahrer sehen nur eigene Lieferungen und – nur wenn „Fahrer dürfen offene Aufträge übernehmen“ eingeschaltet ist – offene Aufträge, die für alle freigegeben sind | U |
| Vollständiger Datenexport, Protokoll, Löschen von Personen, Einstellungen, Branding und Büro-Zugänge nur für Admins; Disponenten verwalten Lieferungen, Fahrer und Fahrzeuge | U |
| Mandantentrennung im Kern der Anwendung ( `core/engine.js` ): jede Abfrage und jede Aktion prüft die `tenantId` des angemeldeten Nutzers | U |
| Automatisierte Tests stellen sicher, dass ein Mandant keine Daten eines anderen Mandanten lesen oder ändern kann und dass Rollen keine fremden Rechte erhalten | U |
| Die Tests laufen vor jeder Auslieferung | [U/G] |
| Lizenzgeber-Konsole ohne Zugriff auf Auftragsdaten (nur Kennzahlen, Firmen- und Lizenzdaten, Abrechnung); es gibt nur einen Lizenzgeber-Zugang | U |
| Setzt der Lizenzgeber das Passwort eines Kunden-Admins zurück (Support-Fall „Admin ausgesperrt“), steht der Vorgang im Protokoll des Kunden, alle Sitzungen dieses Admins enden, und das Einmalpasswort muss bei der nächsten Anmeldung ersetzt werden | U |
| Freigabe des Support-Zugriffs durch den Admin des Kunden für 24 Stunden, vorzeitig beendbar, Freigabe und Ende im Audit-Log | U |
| Support-Modus mit nur lesendem Zugriff für benannte Mitarbeiter des Anbieters (AVV Anlage 4) – derzeit nicht vorhanden; die Freigabe eröffnet keinen technischen Zugriff | G |
| Dateien (Fotos, Dokumente, Unterschriften) werden nur nach Prüfung von Sitzung, Mandant und Rolle ausgeliefert, Fahrer erhalten nur Dateien eigener Lieferungen; Datei-Kennungen sind zufällig (96 Bit); öffentlich abrufbar sind nur Logo und App-Symbol (Anmeldeseite, Startbildschirm) | U |
| Live-Ereignisse (Server-Sent Events) und Push-Benachrichtigungen werden nur an berechtigte Nutzer desselben Mandanten zugestellt; Fahrer erhalten nur Ereignisse zu eigenen und zu offenen, für alle freigegebenen Aufträgen. Die Lizenzgeber-Konsole erhält zu jeder Änderung nur die Art und die Kennung des Datensatzes, keine Inhalte | U |
| Vor jedem Live-Ereignis und alle 25 Sekunden prüft der Server Sitzung, Zugang und Lizenz erneut und beendet die Verbindung, wenn eines davon nicht mehr gilt | U |
| Nach der Kündigung (Status „Gekündigt“) kann sich nur noch der Admin anmelden; bestehende Sitzungen von Disponenten und Fahrern enden mit der nächsten Anfrage | U |

| Maßnahme | Status |
|---|---|
| Bei Sperre oder Ablauf des Mandanten enden bestehende Sitzungen der Fahrer mit der nächsten Anfrage, neue Anmeldungen von Fahrern werden abgewiesen; Admins und Disponenten behalten nur Lesezugriff; die REST-API ist gesperrt | U |
| Die E-Mail-Adresse eines Büro- oder Lizenzgeber-Zugangs ist plattformweit eindeutig; E-Mail-Adressen von Fahrern sind nur Kontaktangaben und spielen bei keiner Anmeldung eine Rolle | U |

## 2.4 Trennungskontrolle

| Maßnahme | Status |
|---|---|
| Logische Trennung der Mandanten über `tenantId` in allen Datensätzen, erzwungen im Anwendungskern (siehe 2.3); Dateien je Mandant in einem eigenen Verzeichnis | U |
| Getrennte Umgebungen für Entwicklung, Test und Produktion; in Entwicklung und Test keine Echtdaten der Kunden | [U/G] |
| Online-Demo arbeitet mit lokaler Engine und erfundenen Demodaten im Browser, getrennt vom Produktivsystem | U |

## 2.5 Pseudonymisierung und Datenminimierung

| Maßnahme | Status |
|---|---|
| Keine Dauerortung; Standort nur beim Tippen auf einen Statusschritt oder beim Melden eines Problems, nur wenn vom Kunden eingeschaltet („Standort beim Statuswechsel“, Voreinstellung aus), vom Fahrer in der App zugestimmt und im Gerät freigegeben; der Server prüft Einstellung und Zustimmung bei jeder Meldung und rundet die Koordinaten auf 5 Nachkommastellen | U |
| Fahrsperre wertet die Geschwindigkeit ausschließlich im Gerät aus; keine Übertragung oder Speicherung der dafür genutzten Positionen; keine Aufzeichnung, wann die Sperre ausgelöst hat | U |
| Fotos werden im Gerät auf höchstens 1.400 Pixel Kantenlänge verkleinert und neu als JPEG gespeichert; dabei gehen Metadaten (EXIF, insbesondere GPS-Koordinaten) verloren. PDF-Dateien werden unverändert hochgeladen. | U |
| Push-Nachrichten enthalten Titel und Text der Mitteilung (z. B. Buchungsnummer, Route mit Orten, Status, Name des Fahrers, bei Notizen und Problemen den Anfang des Textes, bei Rückgaben und Stornierungen den Grund, bei einer 24-Stunden-Sperre den Namen des gesperrten Zugangs), keine Fotos und Dokumente | U |
| Das Anwendungsprotokoll enthält je Anfrage nur Zeitpunkt, Methode, Pfad, Statuscode und Dauer, keine IP-Adressen und keine Inhalte | U |
| IP-Adressen und bei Fehlversuchen eingegebene Kennungen im Audit-Log werden nach 90 Tagen automatisch entfernt | U |
| Zugriffsprotokolle des vorgeschalteten Webservers: IP-Adressen werden nach [7] Tagen gelöscht | [U/G] |
| Aggregierte Kennzahlen je Mandant für Abrechnung ohne Personenbezug (Anzahl Fahrer, Büro-Zugänge, Fahrzeuge, Lieferungen) | U |

# 3. Integrität (Art. 32 Abs. 1 lit. b DSGVO)

## 3.1 Weitergabekontrolle

| Maßnahme | Status |
|---|---|
| TLS für alle Übertragungen zwischen Geräten, Server und Sicherungsziel | [U/G] |
| Ende-zu-Ende-verschlüsselte Nutzlast bei Web-Push (aes128gcm nach RFC 8291, Absenderkennung VAPID nach RFC 8292); Push-Dienste können Inhalte nicht lesen | U |
| Datensicherungen werden vor der Übertragung mit [AES-256] verschlüsselt; Schlüssel getrennt von den Sicherungen verwahrt | [U/G] |
| Vollständiger Datenexport (ZIP mit allen Dateien, JSON) nur durch Admins; die Lieferliste als CSV und Berichte als CSV auch durch Disponenten; jeder Export (ZIP, JSON, CSV, Bericht) steht mit Zeitpunkt, Person und IP-Adresse im Audit-Log | U |
| CSV-Exporte (Server und Büro-Oberfläche) entschärfen Formeln: Textzellen, die mit `=`, `+`, `-`, `@`, Tabulator oder Wagenrücklauf beginnen, erhalten ein vorangestelltes Apostroph, damit Tabellenprogramme sie nicht als Formel ausführen; Zahlen bleiben unverändert | U |
| Keine Einbindung externer Skripte, Schriften, Karten oder Tracker; Schriften werden vom eigenen Server ausgeliefert; Kartendienste nur als Link, der sich nach einem Klick öffnet | U |

## 3.2 Eingabekontrolle

| Maßnahme | Status |
|---|---|
| Audit-Log je Mandant mit Zeitpunkt, handelnder Person, Rolle, Ziel und – bei Anfragen über den Server – IP-Adresse für: Anmeldungen und fehlgeschlagene Anmeldungen (auch falsche Codes der Zwei-Faktor-Anmeldung); Passwortänderungen; Ein- und Ausschalten der Zwei-Faktor-Anmeldung; Anlegen, Ändern, Sperren, Entsperren und Löschen von Nutzern; Zurücksetzen von PIN oder Passwort (auch durch den Lizenzgeber); Anlegen, Ändern, Löschen und Freigeben von Fahrzeugen; Anlegen, Ändern und Stornieren von Lieferungen; Änderungen an Firma, Branding und Einstellungen; Erzeugen und Abschalten des API-Schlüssels; Freigabe und Ende des Support-Zugriffs; jeder Export; Kündigungs- und Tarifwünsche des Admins; Zustimmung und Widerruf beim Standort | U |
| Statusschritte, Rücknahmen, Notizen, Dokumente und Problemmeldungen stehen im Verlauf der jeweiligen Lieferung (Zeitstrahl) mit Zeitpunkt und Person, nicht im Audit-Log | U |
| Doppelte Meldungen werden verhindert: Jede schreibende Aktion trägt eine zufällige Kennung; trifft dieselbe Kennung erneut ein (z. B. nach einer verlorenen Antwort im Funkloch), liefert der Server das gespeicherte Ergebnis, statt die Aktion noch einmal auszuführen; die Kennungen werden 7 Tage aufbewahrt | U |
| Aufbewahrung des Audit-Logs 3 Jahre; IP-Adressen und eingegebene Kennungen darin 90 Tage | U |
| Rücknahmen sind nur dem Fahrer für den eigenen letzten Schritt innerhalb von 2 Minuten möglich und werden als eigenes Ereignis gespeichert; der zurückgenommene Schritt bleibt markiert im Verlauf | U |
| Das Büro kann Schritte weder zurücknehmen noch einen Auftrag für den Fahrer bestätigen; es kann nur den nächsten Schritt für den Fahrer setzen (z. B. nach telefonischer Meldung); dieser Eintrag ist als Eintrag des Büros gekennzeichnet | U |
| Änderungen an Lieferdaten stehen im Verlauf mit Person, Zeitpunkt und Namen der geänderten Felder; frühere Werte speichert die Plattform nicht. Abgeschlossene und stornierte Lieferungen lassen sich nur noch bei Auftraggeber, Referenz und interner Notiz ändern | U |

| Maßnahme | Status |
|---|---|
| Bei Schritten, die ohne Netz getippt und später gesendet werden, speichert der Server den Zeitpunkt des Tippens (Gerätezeit) und zusätzlich die Eingangszeit. Die Gerätezeit gilt nur, wenn sie höchstens 2 Minuten in der Zukunft und höchstens 72 Stunden zurück liegt und nicht vor dem vorigen Schritt der Lieferung; sonst gilt die Eingangszeit. Verspätete Schritte stehen im Verlauf an ihrer zeitlichen Stelle | U |
| Kennzeichnung offline erfasster Schritte im Verlauf und im Abliefernachweis (die Eingangszeit ist gespeichert, wird aber nicht angezeigt) | G |
| [Prüfsumme (SHA-256) je Datei, Ausweis im Abliefernachweis] | G |

## 3.3 Schutz der Anwendung

| Maßnahme | Status |
|---|---|
| Content-Security-Policy ohne externe Quellen: `default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self'; connect-src 'self'; worker-src 'self'; manifest-src 'self'; frame-ancestors 'none'; base-uri 'self'; form-action 'self'; object-src 'none'`; hochgeladene Dateien zusätzlich mit `default-src 'none'; sandbox` | U |
| weitere Sicherheits-Header: `X-Content-Type-Options: nosniff`, `Referrer-Policy: same-origin`, `X-Frame-Options: DENY`, `Cross-Origin-Opener-Policy: same-origin`, `Permissions-Policy: camera=(self), geolocation=(self), microphone=(), payment=(), usb=()` | U |
| Upload-Prüfung: erlaubte Dateitypen JPEG, PNG, WebP und PDF (Logo und Unterschrift ohne PDF), Prüfung des tatsächlichen Dateiinhalts (Signatur), höchstens 10 MB je Bild und 15 MB je PDF (Anfragen über 15 MB lehnt der Server schon anhand der angekündigten Größe ab), höchstens 30 Uploads je Person und Minute, Speicherung außerhalb des Web-Verzeichnisses unter zufälligem Dateinamen; ein abgelehnter Upload hinterlässt keine Datei | U |
| Speicherkontingent je Mandant nach Tarif (Start 5 GB, Flotte 50 GB, Premium 250 GB); ein Upload über dem Kontingent wird abgelehnt (siehe 4) | U |
| Push-Abonnements nur für die Push-Dienste von Google, Apple, Mozilla und Microsoft (nur `https`, Standard-Port, feste Liste der Server-Namen); höchstens 10 Abonnements je Person, das älteste fällt weg; Abmelden eines Abonnements nur durch den eigenen Nutzer; Versand ohne Weiterleitungen und mit 15 Sekunden Zeitlimit | U |
| Schutz vor Cross-Site-Request-Forgery: schreibende Anfragen an die Schnittstelle nur mit der Kopfzeile `X-Ladeklar: 1`, dazu `SameSite=Lax` | U |
| Eingabevalidierung und parametrisierte Datenbankabfragen; Ausgabe-Kodierung gegen Cross-Site-Scripting; Plausibilitätsgrenzen für Gewicht, Paletten und Zeitfenster | U |
| Begrenzung der Anmeldeversuche (20 je IP-Adresse und Minute), der Abrufe von Einladungsdaten (60 je IP-Adresse und Minute), der Uploads (30 je Person und Minute) und der REST-API (600 Anfragen je Mandant und Minute) | U |
| Begrenzung aller übrigen Anfragen je Zugang und IP-Adresse | G |
| Fehler in einer einzelnen Anfrage beenden den Server-Prozess nicht; der ZIP-Export liest die Dateien nacheinander und blockiert andere Anfragen nicht | U |
| Keine Laufzeit-Abhängigkeiten aus Paketverwaltungen und kein Web-Framework; eingebettet sind nur eine QR-Code-Bibliothek und die Symbole von Lucide | U |
| Regelmäßige Prüfung von Node.js und den eingebetteten Bibliotheken auf bekannte Schwachstellen | [U/G] |

## 4. Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b DSGVO)

| Maßnahme | Status |
|---|---|
| Rechenzentrum mit redundanter Strom- und Netzanbindung, USV, Klimatisierung, Brandfrüherkennung (Nachweis durch Zertifikat) | [U/G] |
| Mindestens tägliche, verschlüsselte Datensicherung von Datenbank und Dateien an einen räumlich getrennten Ort in Deutschland ([Backup-Anbieter]); Aufbewahrung 30 Tage rollierend | [U/G] |
| Überwachung der Erreichbarkeit im Minutentakt, Alarmierung der Bereitschaft | [U/G] |
| Offline-Warteschlange in der Fahrer-App überbrückt Funklöcher und kurze Unterbrechungen; Schritte, Fotos, Unterschrift und Problemfoto werden streng der Reihe nach nachgesendet. Bei Netzfehlern, Zeitüberschreitung, Serverfehlern (5xx) und Anfragebegrenzung bleiben die Einträge erhalten; ein Eintrag fällt nur bei einer endgültigen Ablehnung weg und erscheint dann als „Nicht gesendet“. Die App startet auch ohne Netz mit den zuletzt geladenen Touren | U |
| Patch-Management: Sicherheitsaktualisierungen von Betriebssystem und Node.js 22 (LTS) innerhalb von [14] Tagen, bei kritischen Schwachstellen innerhalb von [72] Stunden | [U/G] |
| Speicherkontingente je Mandant mit Mitteilung an die Admins bei 80 % und bei 100 % Belegung, Anzeige der Belegung auf der Lizenz-Seite und in der Lizenzgeber-Konsole, Hinweis auf allen Büro-Seiten bei vollem Speicher | U |
| Überlaufpuffer, damit Uploads laufender Zustellungen bei vollem Speicher nicht scheitern – derzeit lehnt die Plattform bei 100 % jeden weiteren Upload ab, auch Lieferschein-Fotos und Unterschriften der Fahrer | G |
| Schutz vor Überlastung durch Anfragebegrenzung [und vorgelagerten DDoS-Schutz des Hosting-Anbieters] | [U/G] |

## 5. Wiederherstellbarkeit (Art. 32 Abs. 1 lit. c DSGVO)

| Maßnahme | Status |
|---|---|
| Dokumentiertes Wiederherstellungsverfahren für Datenbank und Dateien | [U/G] |
| Wiederherstellungstests mindestens vierteljährlich, mit Protokoll (Datum, Dauer, Ergebnis) | [U/G] |
| Zielwerte: Wiederherstellungszeit [8 Stunden / Premium 4 Stunden], maximaler Datenverlust [24 Stunden / 15 Minuten] | [U/G] |
| Notfallplan mit Zuständigkeiten, Kontaktliste und Kommunikationsvorlagen | [U/G] |

## 6. Verfahren zur regelmäßigen Überprüfung (Art. 32 Abs. 1 lit. d DSGVO)

| Maßnahme | Status |
|---|---|
| Jährliche Überprüfung und Aktualisierung dieser TOM; zusätzlich bei wesentlichen Änderungen der Technik | [U/G] |
| Automatisierte Tests zu Rechten und Mandantentrennung bei jeder Änderung | [U/G] |
| [Jährlicher externer Sicherheitstest (Penetrationstest)] | [G] |
| Verfahren zur Behandlung von Sicherheitsvorfällen und Datenschutzverletzungen mit Meldung an Kunden innerhalb von [24] Stunden (AVV § 9) | [U/G] |

| Maßnahme | Status |
|---|---|
| Verfahren zur Entgegennahme und Behandlung von Schwachstellenmeldungen ( `security.txt` , [Sicherheits-E-Mail]); für Store-Apps zusätzlich Meldewege nach Art. 14 CRA | [U/G] |
| Prüfung der Unterauftragsverarbeiter vor Beauftragung und danach [jährlich] | [U/G] |

## 7. Auftragskontrolle und Organisation

| Maßnahme | Status |
|---|---|
| Schriftliche bzw. elektronische Verträge nach Art. 28 DSGVO mit allen Unterauftragsverarbeitern | [U/G] |
| Verpflichtung aller Mitarbeiter und freien Mitarbeiter auf Vertraulichkeit und Datenschutz vor Aufnahme der Tätigkeit | [U/G] |
| Datenschutz- und Sicherheitsschulung bei Einstellung und danach jährlich | [U/G] |
| Berechtigungen nach dem Prinzip der minimalen Rechte; Entzug aller Zugänge beim Ausscheiden am letzten Arbeitstag | [U/G] |
| Verzeichnis von Verarbeitungstätigkeiten als Verantwortlicher (Art. 30 Abs. 1) und als Auftragsverarbeiter (Art. 30 Abs. 2) | [U/G] |
| Benennung eines Datenschutzkontakts bzw. Datenschutzbeauftragten: [Datenschutzkontakt] | [U/G] |
| Arbeitsplatzgeräte mit Festplattenverschlüsselung, Bildschirmsperre und aktuellen Updates | [U/G] |

## 8. Löschkonzept

| Datenart | Frist | Verfahren |
|---|---|---|
| Abgeschlossene und stornierte Lieferungen mit Verlauf, Notizen, Dokumenten, Fotos und Unterschriften | nach Einstellung des Kunden (Voreinstellung 3 Jahre, einstellbar 1–10 Jahre), gerechnet ab der Zustellung bzw. Stornierung; spätere Änderungen (z. B. eine Notiz) verschieben die Frist nicht | automatische Löschung von Lieferung und Dateien (auch vom Datenträger) bei der stündlichen Wartung; eine Ausnahme einzelner Lieferungen (z. B. Streitfall) gibt es nicht |
| Einzelne Dokumente, die Büro oder Fahrer aus einer Lieferung entfernen | sofort | Datensatz und Datei auf dem Datenträger werden gelöscht, der belegte Speicher sinkt |
| Hochgeladene Dateien, die keiner Lieferung, keinem Logo und keiner Unterschrift zugeordnet sind | 24 Stunden nach dem Upload | automatisch bei der stündlichen Wartung; Dateien auf dem Datenträger ohne Datensatz und abgebrochene Uploads nach 1 Stunde |
| Standortangaben in Statusmeldungen und Problemmeldungen | 90 Tage nach der Meldung (fest) | automatische Löschung der Koordinaten |

| Datenart | Frist | Verfahren |
|---|---|---|
| Stammdaten ausgeschiedener Nutzer | bis der Admin die Person löscht | Anonymisierung: Name wird „Gelöschter Nutzer“; E-Mail, Telefon, Personalnummer, Führerscheinklasse, Notiz, Passwort- bzw. PIN-Hash, Schlüssel der Zwei-Faktor-Anmeldung, Einladungs-Token, Standort-Zustimmung und Mitteilungen werden gelöscht, Sitzungen und Push-Abonnements beendet; abgeschlossene Lieferungen behalten den Bezug. Eine automatische Löschung gesperrter Zugänge gibt es nicht. |
| In-App-Benachrichtigungen | 90 Tage; höchstens 100 je Nutzer | automatisch |
| Audit-Log des Mandanten | 3 Jahre; IP-Adressen und eingegebene Kennungen 90 Tage | automatisch |
| Sitzungen | Abmeldung; Passwortänderung (alle anderen Geräte); Reset von PIN oder Passwort, Sperren oder Löschen des Zugangs; Kündigung (Disponenten, Fahrer) bzw. Sperre und Ablauf (Fahrer) des Mandanten; sonst 90 Tage (Fahrer) bzw. 14 Tage (Büro, Lizenzgeber) ohne Nutzung | automatisch |
| Push-Abonnements | Abmeldung in der App oder Schalter in der App; Passwortänderung, Reset von PIN oder Passwort, Sperren oder Löschen des Zugangs oder des Mandanten; mehr als 10 Abonnements je Person (das älteste); Rückmeldung des Push-Dienstes, dass das Abonnement ungültig ist | automatisch |
| Kennungen gegen doppeltes Senden mit dem gespeicherten Ergebnis der Aktion | 7 Tage | automatisch |
| Einladungs-Token für Fahrer | bei der Anmeldung über den Link, sonst nach 14 Tagen ungültig; ein neuer PIN ersetzt es | automatisch |
| Zugriffsprotokolle des vorgeschalteten Webservers mit IP-Adresse | [7] Tage | [automatisch] |

| Datenart | Frist | Verfahren |
|---|---|---|
| Kundendaten nach Vertragsende | 30 Tage Abrufzeitraum, danach Löschung innerhalb von [30] Tagen | Der Lizenzgeber löscht den Mandanten in der Konsole (nur im Status „Gekündigt“, Bestätigung durch Eingabe des Firmencodes): Lieferungen, Dateien samt Verzeichnis auf dem Datenträger, Nutzer, Fahrzeuge, Mitteilungen, Audit-Log, Kennungen gegen doppeltes Senden, Sitzungen und Push-Abonnements. Im Protokoll des Lizenzgebers bleibt ein Eintrag mit Firmencode, Name und Anzahl der gelöschten Nutzer und Dateien. Die Frist überwacht der Anbieter; eine automatische Löschung gibt es nicht. Bestätigung auf Verlangen. |
| Datensicherungen | 30 Tage rollierend | Überschreiben im Sicherungszyklus |
| Datenträger | bei Austausch | Löschung bzw. Vernichtung durch das Rechenzentrum nach anerkanntem Standard (Nachweis durch Zertifikat) |

## 9. Hinweise für Kunden (Maßnahmen im Verantwortungsbereich des Kunden)

1. Fahrer-Geräte mit Bildschirmsperre und Geräteverschlüsselung betreiben; die Offline-Warteschlange (einschließlich Fotos und gegebenenfalls Standort) und die zwischengespeicherten Kontoangaben liegen unverschlüsselt im Speicher des Browsers und werden durch die Geräteverschlüsselung geschützt.
2. Bei Verlust eines Geräts PIN bzw. Passwort zurücksetzen; dadurch enden alle Sitzungen und Push-Abonnements dieses Nutzers. Für Büro-Zugänge die Zwei-Faktor-Anmeldung empfehlen bzw. vorgeben (die Plattform erzwingt sie nicht).
3. Zugänge ausscheidender Mitarbeiter sofort sperren und löschen, sobald die Daten nicht mehr gebraucht werden; die Plattform löscht gesperrte Zugänge nicht von selbst.
4. Einladungslinks nur an den jeweiligen Fahrer senden, nicht in Gruppen-Chats; ein Link gilt 14 Tage und für eine Anmeldung, zusammen mit der PIN.
5. Dokumente mit Aufbewahrungspflicht regelmäßig exportieren und GoBD-konform archivieren. Die Löschfrist der Plattform zählt ab der Zustellung bzw. Stornierung einer Lieferung, nicht ab dem Ende des Kalenderjahres; eine kürzere Frist wirkt bei der nächsten stündlichen Wartung (die App zeigt vorher an, wie viele Lieferungen betroffen sind).
6. Vor Vertragsende alle Daten als ZIP exportieren; nach der Löschung durch den Anbieter sind sie nicht wiederherstellbar.

**Prüfhinweis (Technik):** Zeilen mit U und G sind am 17.10.2026 mit dem Code abgeglichen; Zeilen mit [U/G] vor Veröffentlichung bestätigen. Seit der letzten Fassung umgesetzt: Zwei-Faktor-Anmeldung (optional), Hash-Speicherung der API-Schlüssel, einmalige und befristete Einladungslinks, Ende bestehender Sitzungen bei Sperre, Kündigung und Passwortänderung, Gerätezeit bei Offline-Schritten, Speicherkontingente, Löschen der Dateien vom Datenträger, Entschärfung von Formeln in CSV-Dateien. Offen sind insbesondere: Pflicht zur Zwei-Faktor-Anmeldung und verschlüsselte Speicherung ihres Schlüssels, Überlaufpuffer beim Speicher, Kennzeichnung offline erfasster Schritte, allgemeine Anfragebegrenzung, Verschlüsselung und Auslagerung der Sicherungen (`deploy/backup.sh` erzeugt nur ein unverschlüsseltes Archiv auf demselben Server). Gibt es diese Funktionen bei Veröffentlichung nicht, die G-Zeilen mit Termin versehen oder streichen.